THOMSON COURSE TECHNOLOGY

Guide to Network Defense and Countermeasures Third Edition

Chapter 7

Understanding Wireless Security

Objectives

- Explain basic concepts in wireless security
- Describe security solutions for wireless networking
- Describe security solutions for handheld wireless devices

© Cengage Learning 2014

Security Concerns of Wireless Networking

- In this section you will learn:
  - How the Media Access Control (MAC) sublayer of the Data Link layer can create vulnerabilities
  - How passive and active scanning methods are used to find networks to attack
  - Inherent vulnerabilities of IEEE 802.11's authentication mechanisms
  - Common methods for securing wireless networks

© Cengage Learning 2014

IEEE 802.11 Media Access Control: Frames, Part 1

- MAC sublayer of the Data Link layer performs many critical functions:
  - Discover wireless access point, channels, and signal strengths
  - Join wireless networks (includes authentication and association to the access point
  - Transmitting data
  - Maintaining the connection
- Each access point (AP) has a 0- to 32-byte SSID that functions as the name of the network

© Cengage Learning 2014

IEEE 802.11 Media Access Control: Frames, Part 2

- MAC frames are used to locate wireless networks, establish and maintain the connection, and transmit data
- The 802.11 standard has three types of MAC frames:
  - Management frames
  - Control frames
  - Data frames

© Cengage Learning 2014

IEEE 802.11 Media Access Control: Frames, Part 3

- **Management frames**: establish and maintain communications (sent in cleartext with SSIDs)
  - Anyone who intercepts one can discover the SSID

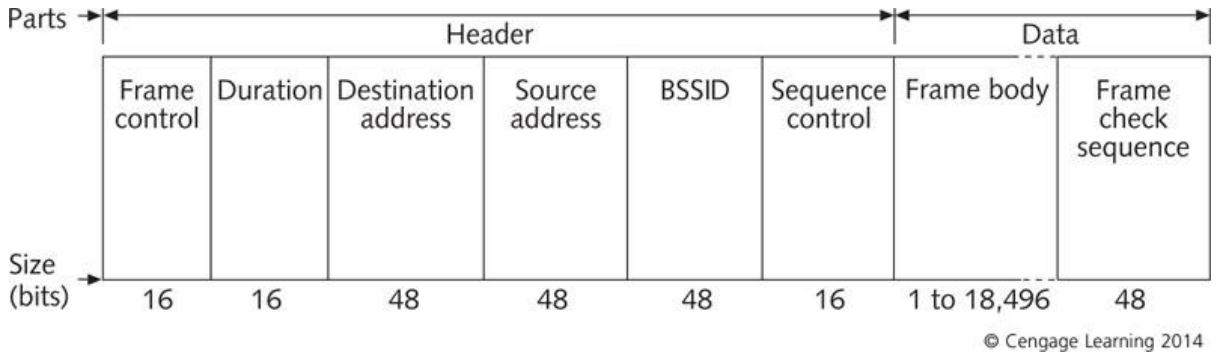


Figure 7-1 An IEEE 802.11 management frame

© Cengage Learning 2014

Management Frame Types

Frame type	Purpose
Association request	Allows an AP to allocate resources for a wireless station
Association response	Sent by the AP in response to an association request frame; indicates whether the request is accepted or rejected
Reassociation request	Sent to the new AP when a wireless station roams into a different AP coverage area (also called a “cell”)
Reassociation response	Sent by the AP in response to a reassociation request frame; indicates whether the request is accepted or rejected
Probe request	Sent by a station when it needs information from another station
Probe response	Sent by a station in response to a probe request frame; indicates capabilities, supported data rates, and other information
Disassociation	Sent by a station to another station if the sender wants to terminate the connection
Authentication	Sent by the AP to determine whether to allow a wireless station to enter the network
Deauthentication	Sent by a station to another station if the sender wants to terminate the connection
Beacon	Sent by an AP to any listening stations to advertise services or information available on the wireless network; beacons contain SSIDs, capabilities, supported rates, and other information about the AP and wireless network

Table 7-1 Management frame types

IEEE 802.11 Media Access Control: Frames, Part 4

- **Control frames**: help deliver data frames between stations and control access to medium
- Four most common types of control frames:
  - Request to send (RTS) – first step of the two-way handshake before sending a data frame
  - Clear to send (CTS) – gives a station clearance to send
  - Acknowledgement (ACK) – after receiving a data frame with no errors, receiving station sends this
  - Power-save poll (PS-Poll) – used when a station has awakened from power-save mode and sees that an AP has frames buffered for it

© Cengage Learning 2014

An IEEE 802.11 Control Frame

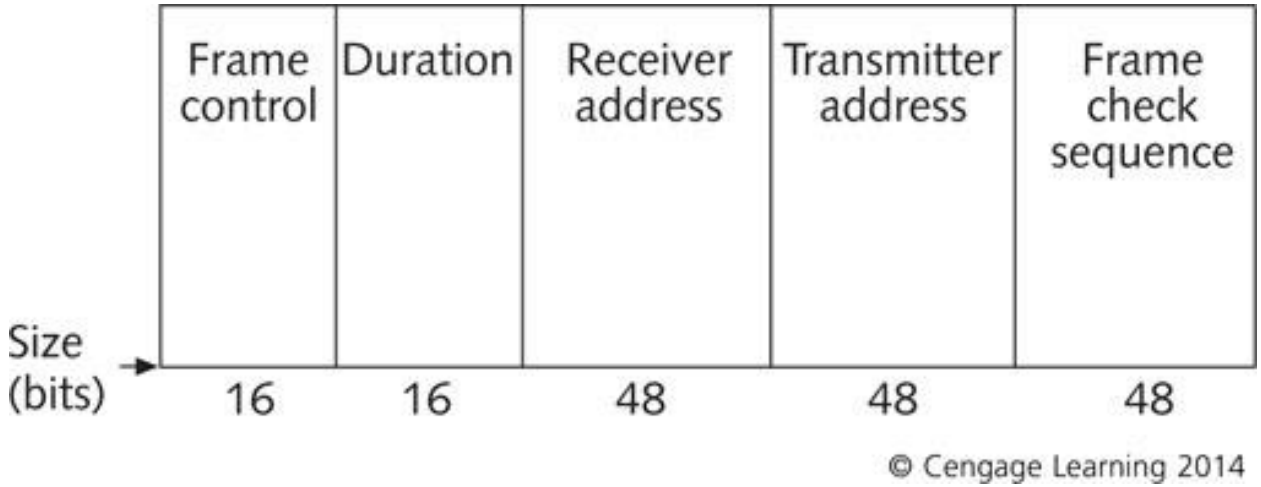


Figure 7-2 An IEEE 802.11 control frame

IEEE 802.11 Media Access Control: Frames, Part 5

- Data frames: carry the TCP/IP datagram and the payload

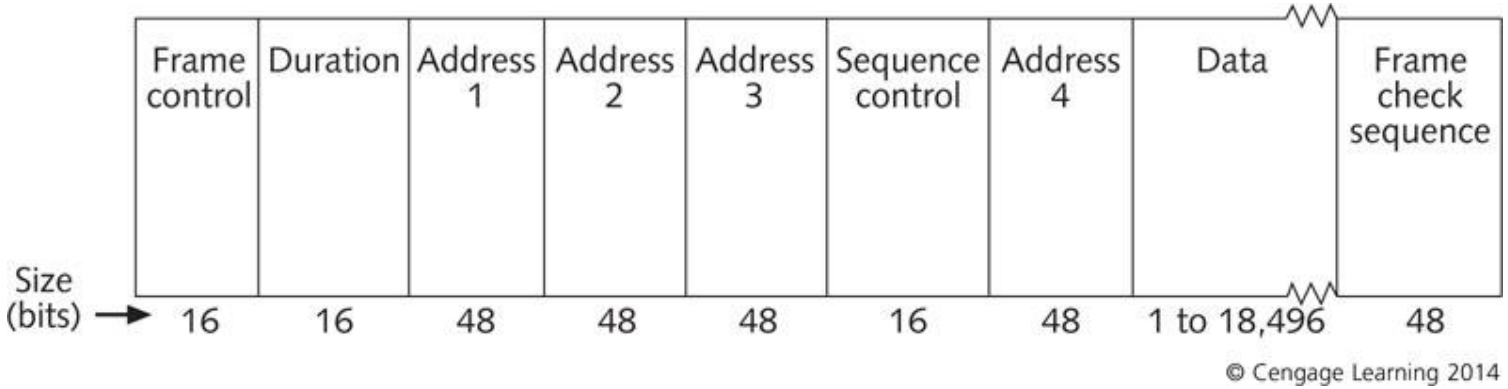


Figure 7-3 An IEEE 802.11 data frame

© Cengage Learning 2014

IEEE 802.11 Media Access Control: Frames, Part 6

- A wireless station could have a null SSID
  - Allows it to match all SSIDs
  - If a beacon frame contains a null SSID, attackers just have to capture frames that contain the correct SSID
- Beaconing can be turned off on most current APs
- **Sniffing**: capturing network traffic during transmission

© Cengage Learning 2014

Scanning and Attacks

- **Passive scanning**: a WNIC listens to each channel for a few packets, then moves to another channel
  - A WNIC's **radio frequency (RF) monitor mode** allows passive scanning
- **Passive attack**: uses passive scanning to gather information about a wireless network for later use
- **Active scanning**: station sends a probe request frame on each available channel and waits for a probe response frame from available APs
- **Active attack**: attackers use several techniques to probe wireless networks in an attempt to gather information
  - Can be detected by network security measures

© Cengage Learning 2014

Common Active Attacks, Part 1

Attack	Method
Jamming (DoS attack)	The attacker floods airwaves with noise to weaken the RF signal and cause the wireless network to stop functioning.
Association flood (DoS attack)	The attacker authenticates several fake stations to send a flood of spoofed association requests, which overflow an AP's association request table. An AP can have up to 2007 concurrent associations before the association request table overflows and refuses further associations.
Forged disassociation (DoS attack)	The attacker sends a forged disassociation frame that contains the spoofed source MAC address of an AP. The target station attempts to reassociate, and the attacker continues to send disassociation frames to prevent reassociation or replies with a reassociation response.
Forged deauthentication	The attacker monitors transmissions to identify target stations. When a data frame or association response frame is captured, the attacker sends a spoofed deauthentication frame that contains the AP's MAC address. To prevent reconnection, the attacker continues to send deauthentication frames for the duration of the attack.
MAC address spoofing	The attacker inserts spoofed values in a frame's sender MAC address field.
Session hijacking	The attacker causes valid users to lose their connections by sending a forged deauthentication or disassociation frame to their stations, for example. The attacker then assumes their identities and privileges by sending their stations' MAC addresses to the AP. The attacker disables users' systems by using a DoS or buffer overflow attack so that their stations cannot reconnect.

Table 7-2 Common active attacks

Common Active Attacks, Part 2

Attack	Method
Brute force	The attacker uses a program that attempts every possible key combination by changing one character at a time systematically; this attack is an attempt to decrypt a message and discover the default key.
Dictionary	In an attempt to determine passphrases, the attacker encodes dictionary words in the same way the passphrase was encoded.

Table 7-2 Common active attacks (continued)

Wardriving and Exploitation of Rogue Devices

- **Wardriving**: a potential attacker drives around with a laptop and WNIC in RF monitor mode to detect unsecured wireless signals
- **Rogue devices**: wireless devices that employees connect and use without authorization or verified configurations
  - Usually configured poorly, so attackers can locate easily

© Cengage Learning 2014

Wireless Man-in-the-Middle Attacks

- Man-in-the-middle (MITM) attack: attackers intercept the transmission of two nodes without the users' knowledge
  - Transmission can be modified and then forwarded to the intended destination, blocked from being delivered, or read and passed on
  - Attackers often set up a fake AP to intercept transmissions
    - Make stations think they are connecting to an authentic AP

© Cengage Learning 2014

A Wireless Man-in-the-Middle Attack

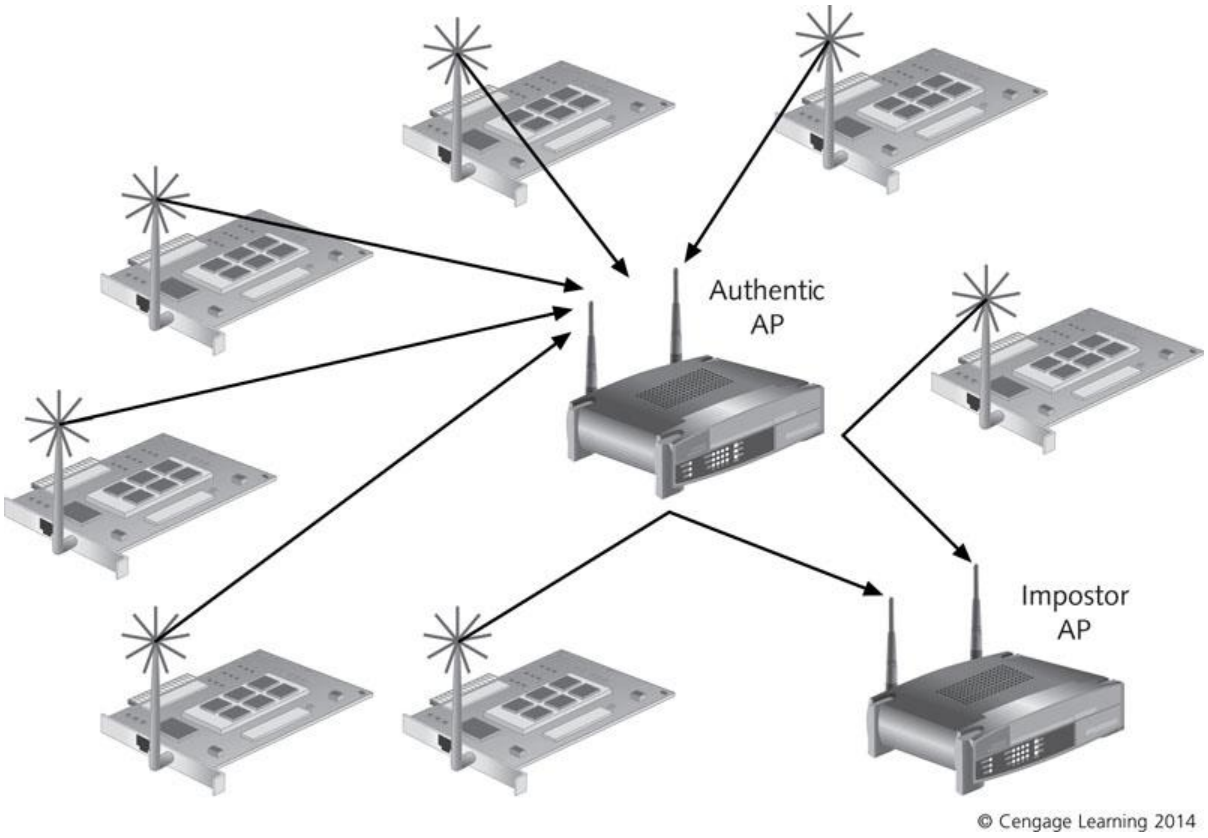


Figure 7-4 A wireless man-in-the-middle attack

Association with a Wireless Network

- To access services and resources:
  - A station must be associated with an AP or other station
- **Association**: Two-step process:
  - A station listens for beacon frames to join a network and goes through authentication process
  - Station sends an association request frame
    - If AP accepts it will send back an association response frame that contains the association ID
- A station can be authenticated to several APs but it can be associated with only one network at a time

© Cengage Learning 2014

Wireless Authentication, Part 1

- Difference between wireless and wired networks:
  - The wireless station, not the user, is authenticated before being connected to the network
- Two types of IEEE 802.11 authentication:
  - Open system authentication – station is authenticated without further checking as long as SSID matches the network it is attempting to join
    - Provides little security
  - Shared key authentication – uses a standard challenge-response process with shared key encryption

© Cengage Learning 2014

Open System Authentication

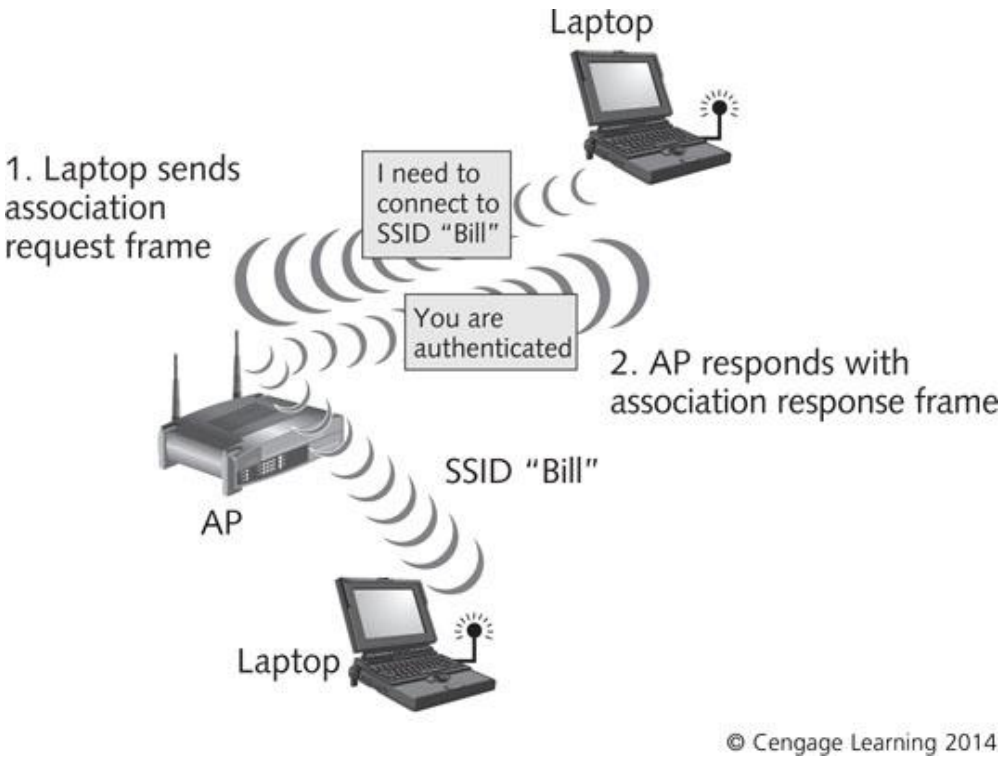


Figure 7-5 Open system authentication

Wireless Authentication, Part 2

- In shared key authentication:
  - Station sends an authentication frame to an AP
  - AP returns an authentication response frame that contains challenge text
  - Station encrypts the text with its shared key and returns it to the AP
  - Using its own copy of the shared key, the AP decrypts the text and compares to original challenge text
    - If they match, AP sends another authentication frame with the results and station is authenticated
    - If they do not match, station is rejected

© Cengage Learning 2014

Shared Key Authentication

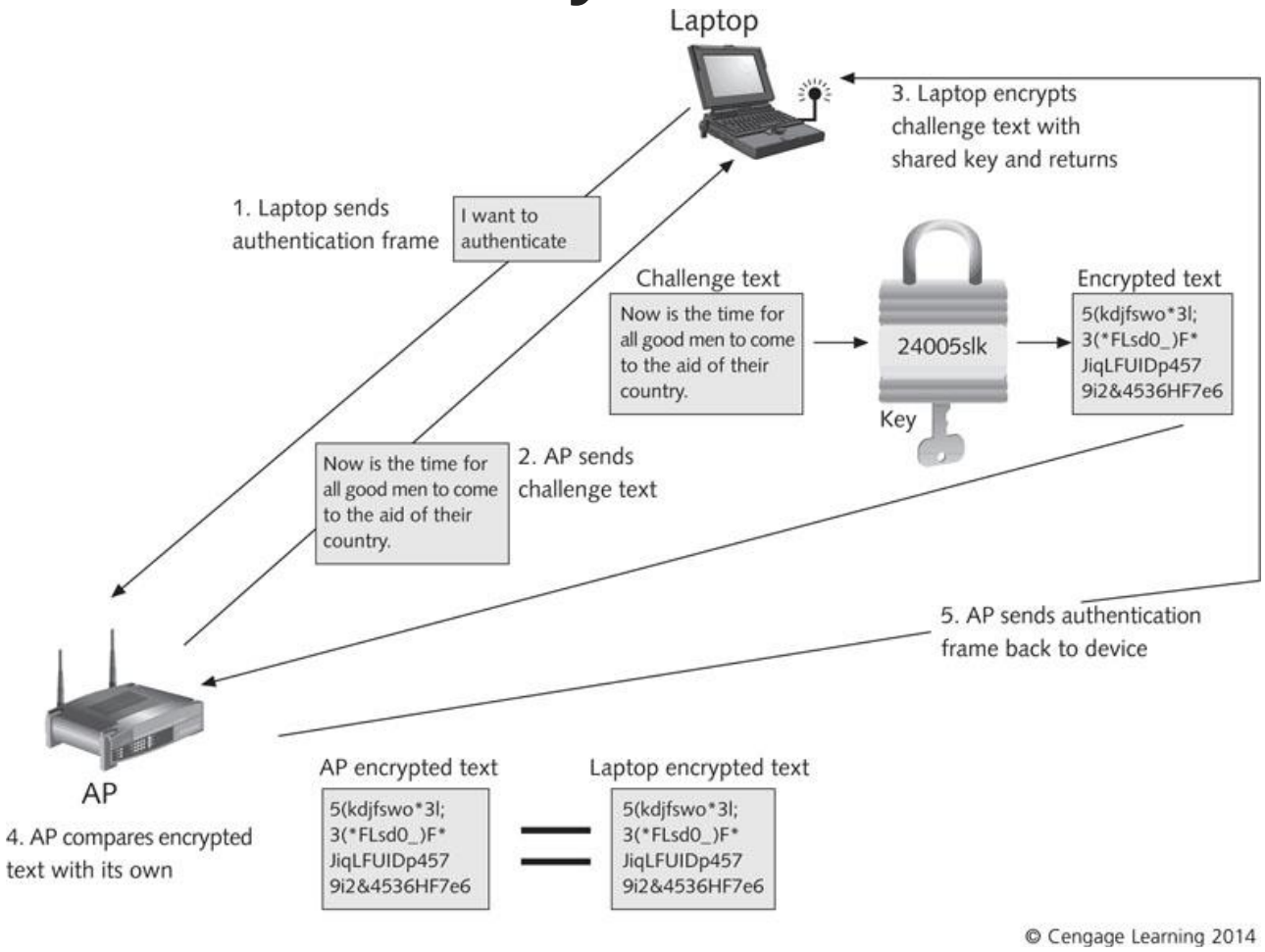


Figure 7-6 Shared Key Authentication

Wireless Authentication, Part 3

- Shared key authentication is considered weak if it uses WEP for encryption
  - Attackers can use passive scanning to capture packets and crack the shared key
- 802.11 standard uses a 40-bit or 104-bit key with a 24-bit **initialization vector (IV)** added to the beginning of the key
  - IV is transmitted in cleartext, giving attackers 24 bits of the key
  - After enough packets have been captured, attackers can crack they key with a brute-force or dictionary attack

© Cengage Learning 2014

Wireless Authentication, Part 4

- WEP provides adequate protection against casual users, but not against attackers determined to gain access
  - Dynamic WEP, a newer version, offers slightly better protections (rotates keys frequently)
  - WEP2 was developed to address WEP vulnerabilities
    - Uses a 120-bit key and Kerberos authentication
    - No more secure than WEP

© Cengage Learning 2014

Default WEP Keys

- APs and stations can hold up to four keys but only one is chosen as the **default key**
  - Does not have to be the same on every station but same key must be used for encryption and decryption

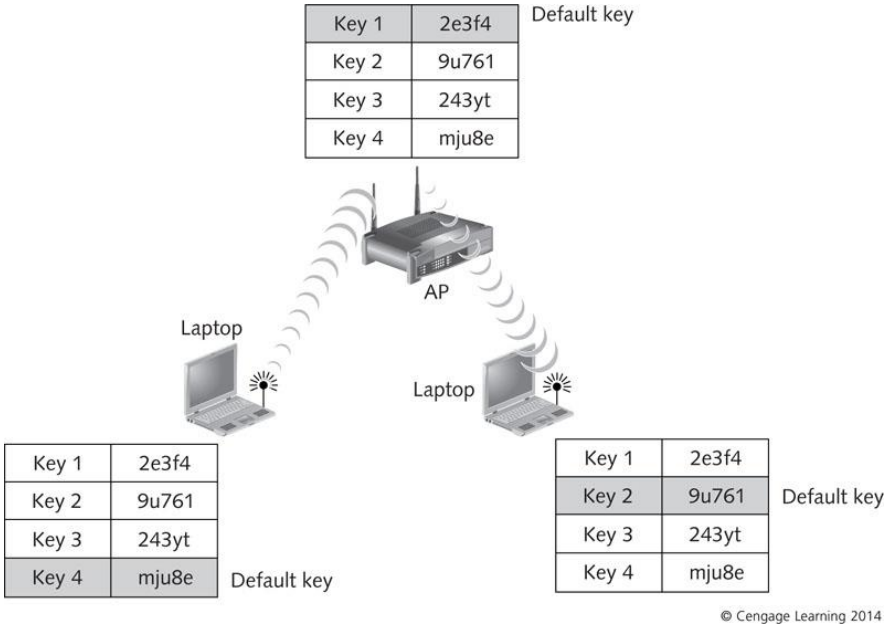


Figure 7-7 Default WEP keys

© Cengage Learning 2014

Key Management Concerns in 802.11 Networks

- 802.11 standard leaves the details of key management up to vendors and users
  - Is a challenge in wireless security
- WEP was intended to prevent casual eavesdropping but does not prevent unauthorized access
  - WEP keys must be installed on all stations in a network, which takes a lot of time
  - Keys are changed infrequently or not at all
- If stronger encryption methods are used, an effective key management method is still crucial

© Cengage Learning 2014

MAC Address Filtering and Spoofing

- Wireless stations use MAC addresses for identification between stations and APs
- MAC addresses are hard-coded into NIC firmware
  - Can use configuration tools to change a WNIC's MAC address
- Basic security mechanism is MAC address filtering
  - Addresses of legitimate stations can be entered into AP's MAC address table so that only recognized stations can connect to the AP
- MAC address spoofing: attackers alter their frames with legitimate MAC addresses

© Cengage Learning 2014

Wireless Device Portability

- Wireless devices are designed to be portable
  - Makes them vulnerable to theft, unauthorized use, improper or unsafe storage and handling, established connection protocols being bypassed, and more
- Mobile devices may not be backed up properly or may not have updates installed
- Make sure highly sensitive data is not stored on mobile devices
  - Must use strong encryption and authentication

© Cengage Learning 2014

Examining Wireless Security Solutions and Countermeasures

- In early years of wired networking, wireless standards focused on connectivity instead of security
  - Wireless security has lagged a few years behind wired network security
- In the following sections you will learn about:
  - Common solutions for addressing security flaws
  - Special security requirements of wireless networks
  - Common configurations that mitigate wireless vulnerabilities and protect against wireless networking threats

© Cengage Learning 2014

Incorporating a Wireless Security Policy, Part 1

- A wireless security policy should address:
  - Scope and goals of the policy
  - Responsibilities for wireless matters and contact information for responsible parties
  - Physical security of APs
  - Approved hardware and software
  - Procedures for requesting, testing, installing, and configuring hardware and software
  - Assignment of responsibilities for installing, maintaining, and managing wireless devices
  - Guidelines and penalties for scanning or accessing the wireless network without authorization

© Cengage Learning 2014

Incorporating a Wireless Security Policy, Part 2

- A wireless security policy should address (cont'd):
  - Explicit statements about the nature of wireless communications, including measures to protect the rest of the network from potential harm
  - Details on wireless security awareness training
  - Internet access via wireless connections
  - Assignment of responsibilities for protecting data, privacy, and devices
  - Penalties for attempting to bypass security measures willfully
  - Requirements for encryption methods, authentication, and storage of confidential data

© Cengage Learning 2014

Ensuring Physical Security

- Best tool for ensuring physical security is to provide security awareness training for users
  - Should be made aware of the potential for theft and consequences of stolen devices
  - Should be trained not to leave wireless devices logged on to the network
  - Include instructions for protecting mobile devices from damage
    - Never leave laptops in cars during summer or winter
    - Never leave laptops unattended in public

© Cengage Learning 2014

Planning AP Placement

- **Site survey**: procedure for assessing the environment and determining where APs are needed to provide adequate coverage
  - Help determine whether to use directional or omnidirectional antennas
  - Also tells you if your signal extends beyond areas that are within your physical control
- Network components require careful placement to provide adequate coverage but prevent indiscriminant radiation of the signal

© Cengage Learning 2014

Changing Default Hardware and Software Settings

- Change the following default settings:
  - SSID – default SSIDs commonly include information about a device's manufacturer
  - Administrator password
  - Beaconing interval – to reduce traffic
  - Manufacturer's keys
  - Channels
  - Security measures
    - MAC ACLS, authentication, and encryption

© Cengage Learning 2014

Strong Encryption and Authentication

- **802.1x and Extensible Authentication Protocol**
  - 802.1x was developed to provide port-based access control on Ethernet LANs
    - Was revised to work for wireless networks
    - Uses Extensible Authentication Protocol (EAP) – a group of management protocols that stations use to request port access and includes a method of secure key exchange
    - Involves three participants: supplicant (station), authenticator (AP), and authentication server (RADIUS server)

© Cengage Learning 2014

802.1x Authentication

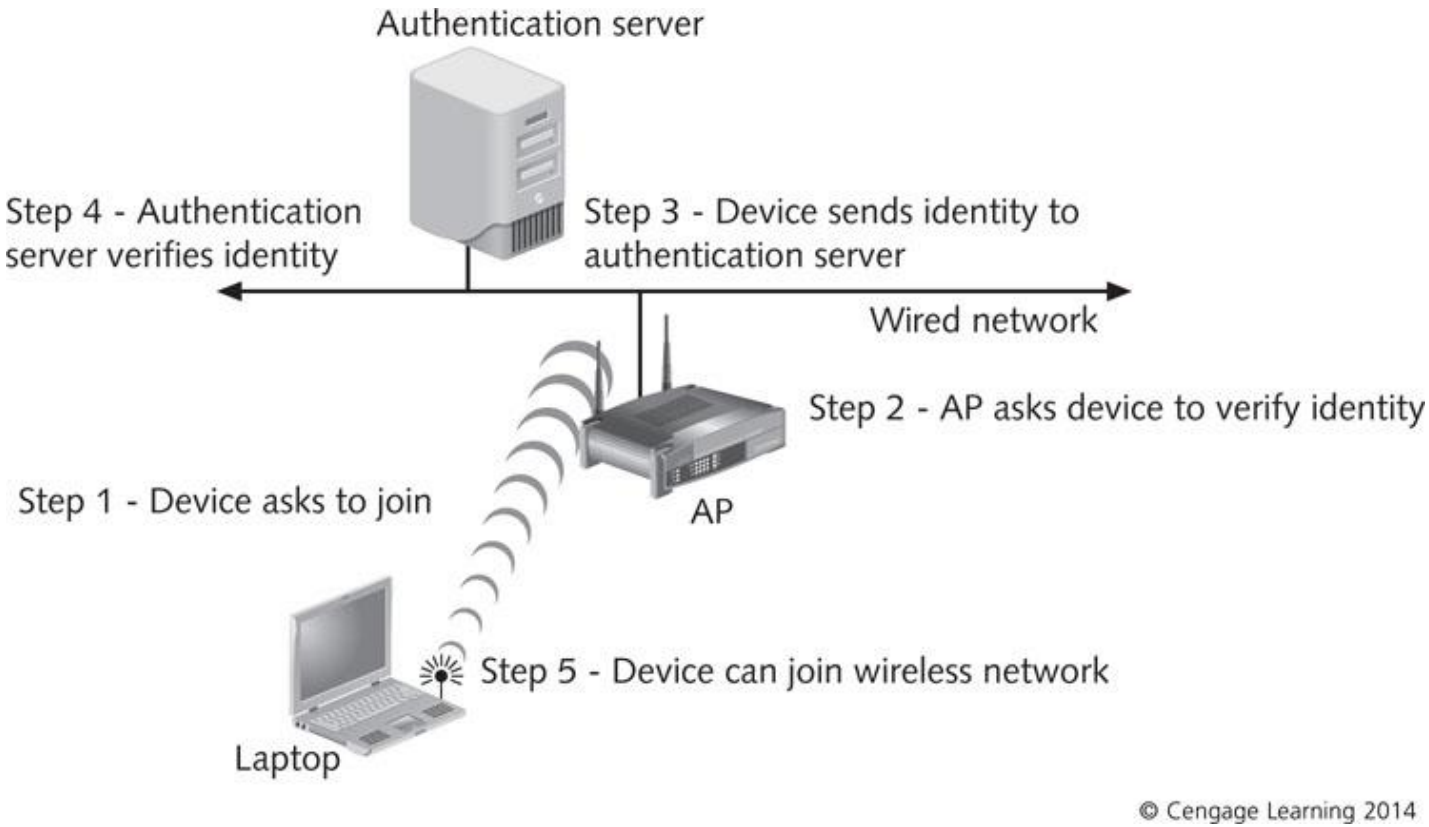


Figure 7-8 802.1x authentication

Strong Encryption and Authentication, Part 1

- **802.11i and Advanced Encryption Standard**
  - Uses 802.1x authentication and Advanced Encryption Standard (AES)
    - AES is strong enough to meet the U.S. Federal Information Processing Standard (FIPS)
      - Is a block cipher which breaks data into blocks of 8 to 16 bits, then encrypts each block separately
      - For additional security, blocks can arranged randomly rather than sequentially

© Cengage Learning 2014

Strong Encryption and Authentication, Part 2

- **Wi-Fi Protected Access (WPA)**
  - Replaced WEP encryption with **Temporal Key Integrity Protocol (TKIP)**
    - TKIP is based on WEP but includes a method for generating new keys for each packet
  - Different TKIP keys
    - **Pairwise keys**: used between a pair of stations
    - **Pairwise master key (PMK):** generates data encryption keys, data integrity keys, and session group keys for multicasts
    - **Pairwise transient key (PTK)**: first key created from the PMK
      - Actually four keys shared between AP and client

© Cengage Learning 2014

Strong Encryption and Authentication, Part 3

- **Wi-Fi Protected Access (WPA)** (cont'd)
  - **Message Integrity Check (MIC):** mathematical function used to check messages for evidence of alteration (similar to cyclic redundancy check – CRC)
  - WPA offers improvements over WEP:
    - Minimum key length is increased
    - IV sequencing is enforced (IVs are not reused)
    - IV length is doubled from 24 bits to 48 bits
    - Packet-tampering detection is built-in
    - Key rotation is automatic

© Cengage Learning 2014

The MIC Process

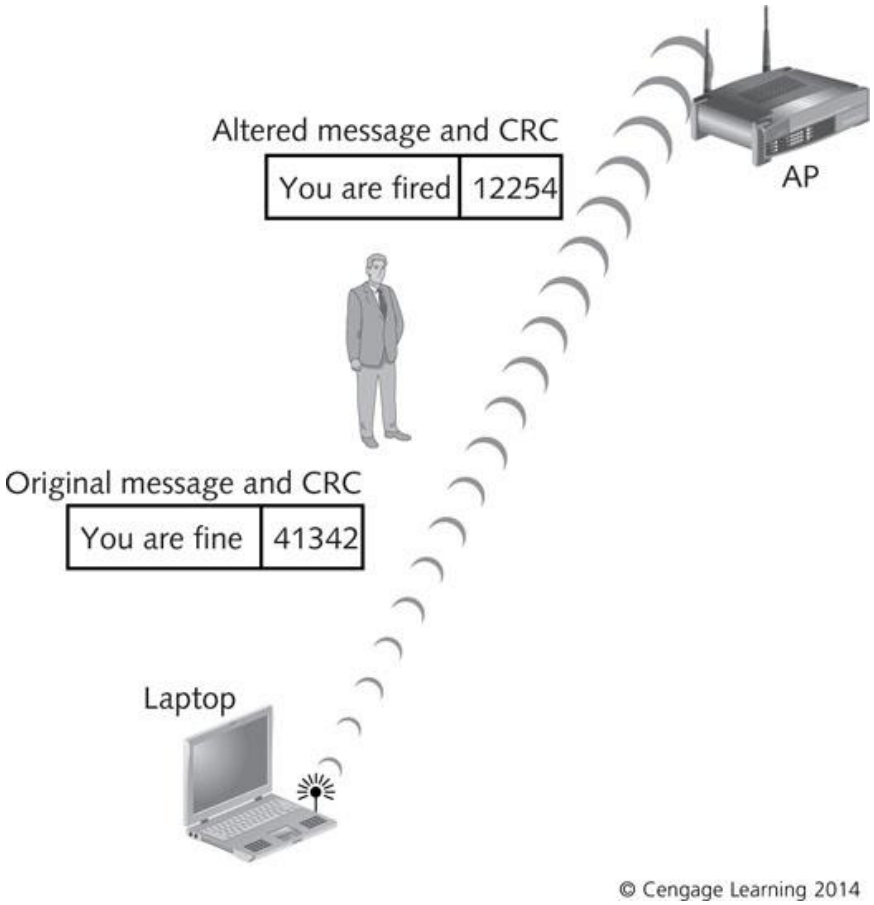


Figure 7-9 The MIC process

Strong Encryption and Authentication, Part 4

- **Wi-Fi Protected Access version 2 (WPA2)**
  - Based on the final ratified 802.11i standard
  - Uses AES for encryption and 802.1x or preshared keys for authentication
  - Allows both TKIP and AES clients to communicate (802.1x recognizes only AES)
- WPA and WPA2 have two modes:
  - Personal Security – for single user or SOHO
  - Enterprise Security – for medium to large businesses

© Cengage Learning 2014

Strong Encryption and Authentication, Part 5

- Recent research has shown serious weaknesses in WPA and WPA2 when using TKIP
  - WPA2-TKIP is now considered far less secure than WPA2-AES
- WPA2-AES Enterprise Security provides the highest security available
- **Wi-Fi Protected Setup (WPS):** protocol designed to automate key distribution in small office and home networks
  - Allows users to enter an eight-digit PIN
  - In 2011, a flaw was discovered that made it unsecure and should be disabled

© Cengage Learning 2014

Wireless Security Solutions

Type	Encryption	Authentication	Key length	Security level
WEP	WEP	Shared key	40-104 bits with a 24-bit IV	Low
WEP2	WEP2	Kerberos	128 bits	Low
Dynamic WEP	Dynamic keys	Various	128 bits	Low
WPA Personal Security	TKIP	PSK	128 bits	Medium
WPA2 (802.11i) Personal Security	AES	PSK	256 bits	Medium to high
WPA Enterprise Security	TKIP	802.1x	128 bits	Medium
WPA2 Enterprise Security	AES	802.1x	256 bits	High

Table 7-3 Wireless security solutions

Wireless Auditing, Part 1

- Auditing wireless networks is an integral part of security management
- Audits are based on security policies
- Hiring third-party experts can be a good idea:
  - They see your network with fresh eyes and no preconceived ideas
  - They are likely to have different skills and tools
  - They have the focus and experience of a specialist
- Check credentials and ask for references

© Cengage Learning 2014

Wireless Auditing, Part 2

- Risk and Security Assessments
  - Risk assessment: identifies what your assets are and how critical they are so you know how to protect them
    - Includes:
      - Inventory of company assets
      - Analysis of possible threats
      - Consequences if a threat materializes
      - Probability that the threat could occur
      - Security controls available to mitigate the risk
      - Organization's acceptable level of risk
  - Security assessment: identifies existing security measures

© Cengage Learning 2014

Wireless Auditing, Part 3

- Auditing Tools
  - **Penetration testing**: intended to identify security vulnerabilities that attackers could exploit
  - Attackers use **sniffers** in the reconnaissance phase to capture packets
    - Used to gather information about targets
  - Auditors use sniffers to see what kind of information attackers can gain by using them
  - Hundreds of sniffing programs are available for PCs, handheld devices, and any available OS

© Cengage Learning 2014

Wireless Sniffers

Name	OS	Description
Aircrack-ng	Mac OS X, Windows, Linux	A sniffer and WEP/WPA key cracker that can be used to launch attacks; consists of airodump-ng (packet capture), airdecap-ng (decryption of WEP/WPA capture files), aircrack-ng (WEP and WPA/PSK cracker), and aireplay-ng (packet injection)
Kismet	POSIX, Linux, BSD, Mac OS X, Win32	An 802.11 Layer 2 detector, sniffer, and IDS that is passive and undetectable in operation; can detect hidden networks, rogue devices, attacks, and unauthorized users
NetStumbler	Windows	An 802.11a, 802.11b, and 802.11g WLAN detector and analyzer; WebStumbler is an add-on that converts files to HTML
Wireshark (previously Ethereal)	Windows, UNIX, Linux, and other Oss and UNIX variations	A network protocol analyzer capable of live monitoring or capture; live data can be read from FDDI, PPP, token ring, Ethernet, and 802.11 networks
AirSnort	Windows, Linux	A tool that recovers encryption keys by using passive monitoring; requires 5 to 10 million packets
FakeAP	Linux, BSD UNIX	A tool that generates thousands of counterfeit 802.11b APs and is useful as a honeypot tool
WPA Cracker	Linux	A tool that prevents dictionary and brute-force attacks against WPA

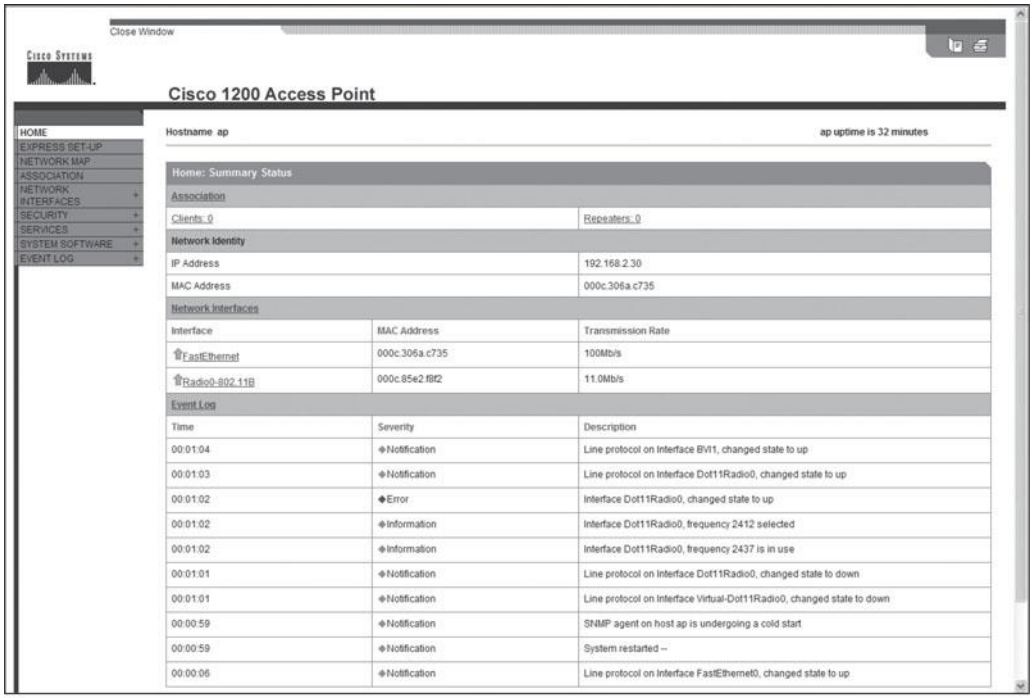
Table 7-4 Wireless sniffers

AP Logging Functions

- Many enterprise-class AP models can maintain complex event logs and connection statistics
- Some can interface with a Simple Network Management Protocol (SNMP) tool
  - SNMP requires an SNMP agent on the device you want to monitor
  - Logged information is stored in the SNMP agent's management information base (MIB)
  - Can set an SNMP alarm that sends an alert message, called an SNMP trap
    - Management station queries all stations for details about the event that triggered alarm

© Cengage Learning 2014

An AP Event Log



Source: Cisco Systems

Figure 7-10 An AP event log

Best Practices for Wireless Network Security, Part 1

- Use strong authentication, such as 802.1x
- Use strong encryption, preferably end to end
- Perform a site survey and place APs strategically
- Make sure that a comprehensive wireless security policy is kept up to date and users are trained
- Change default settings, such as SSIDs
- Avoid using protocols that send traffic in cleartext
- If appropriate, use VPNs for wireless transmissions
- Use wireless IDPSs

© Cengage Learning 2014

Best Practices for Wireless Network Security, Part 2

- Make sure that all stations use updated antivirus protection
- Make sure that wireless devices use firewalls
- Audit the wireless network periodically
- Monitor your wireless network traffic with the best tools available

© Cengage Learning 2014

Mobile Device Security

- Mobile devices that can now access the Internet and use mobile applications for business activities have to be added to the corporate network
- Difficulties:
  - Devices are often outside the physical control of the IT security team
  - Transmission media used might be beyond a company's control
  - Users may synchronize their devices with computers that are not controlled by the corporate IT department
    - Increases the risk of malware infection

© Cengage Learning 2014

Approaches to Mobile Device Security, Part 1

- Checklist that ensures the security of handheld devices should include the following:
  - Device configuration management
  - Critical patch and OS update management
  - Application installation/configuration management
  - Elimination of unneeded applications
  - Antivirus software
  - Firewall software
  - IDPS software
  - Antispam software
  - Antispyware software
  - Remote content erasure capability
  - Remote password reset capability

© Cengage Learning 2014

Approaches to Mobile Device Security, Part 2

- Checklist (continued):
  - VPN software
  - Backup management
  - Authentication management
  - Encryption
  - Log management
  - Incident response policy and procedures
  - Restriction of application downloads
  - Restriction of camera, microphone, removable media use
  - Remote diagnostics
  - Subscriber Identity Module (SIM) security
  - User training

© Cengage Learning 2014

Summary, Part 1

- A major challenge for wireless networking is security
- Wireless networks use the airwaves as a transmission medium, so packets are vulnerable
- The MAC sublayer of the Data Link layer performs many critical functions in a wireless network
- Passive scanning involves listening for beacon frames and a passive attack uses passive scanning to gather information for later use
- Active scanning involves sending probe request frames on each channel and waiting for a response

© Cengage Learning 2014

Summary, Part 2

- A station must be authenticated in order to join a wireless network
- SSIDs and other information are vulnerable in standard 802.11 transmission because management frames send network information in cleartext
- WEP was implemented in original 802.11 and uses a default key for encryption
- Effective security solutions include: IEEE 802.11x, WPA/WPA2, and IEEE 802.11i

© Cengage Learning 2014

Summary, Part 3

- Auditing a wireless network is crucial to maintaining and improving security
- Less sophisticated APs might generate simple logs but enterprise-class models can maintain an event log and can interface with a SNMP tool
- Some best practices for wireless security include training users, developing a wireless security policy, restricting the data stored on portable devices, and ensuring that default settings are changed

© Cengage Learning 2014